ISO 27001:2022 COMPLIANCE CHECKLIST

For Startups & Small-to-Medium Enterprises (SMEs)

Based on ISO/IEC 27001:2022 | Practical Implementation Guide

How to Use This Checklist

Use the following status codes to track your progress against each control:

Symbol	Status	Meaning
✅	Done	Control is fully implemented and evidenced
🔄	In Progress	Partially implemented or actively being worked on
❌	Not Started	Not yet addressed
⚠️	N/A	Not applicable — document justification in SoA

> ℹ️ *Start with Clauses 4–6 to build your ISMS foundation, then address the Annex A controls most relevant to your risk profile.*

Clause 4 – Context of the Organization

4.1 Understanding the Organization and Its Context

- ☐ Identified internal factors that affect information security (culture, systems, processes)
- ☐ Identified external factors (regulatory, market, technology, competitive environment)
- ☐ Documented context in a Context of the Organization document or equivalent

4.2 Understanding the Needs of Interested Parties

- ☐ Listed all relevant interested parties (customers, regulators, investors, employees, partners)
- ☐ Documented their information security requirements and expectations
- ☐ Reviewed requirements regularly and updated as needed

4.3 Determining the Scope of the ISMS

- ☐ Defined the scope of the ISMS- This is the most important step
- ☐ Scope includes boundaries, locations, assets, and technologies
- ☐ Documented and approved scope statement
- ☐ Interfaces and dependencies outside the scope are identified

4.4 Information Security Management System

- ☐ Established, implemented, and maintains an ISMS
- ☐ ISMS continually improved in line with ISO 27001:2022 requirements

Clause 5 – Leadership

5.1 Leadership and Commitment

- ☐ Top management demonstrates commitment to the ISMS
- ☐ Information security policy established and communicated
- ☐ Roles, responsibilities, and authorities assigned
- ☐ Resources for ISMS are provided
- ☐ Information security integrated into business processes

5.2 Policy

- ☐ Information Security Policy documented and approved by top management
- ☐ Policy includes commitment to satisfy applicable requirements
- ☐ Policy includes commitment to continual improvement
- ☐ Policy communicated to all employees and relevant stakeholders
- ☐ Policy available to external parties as appropriate
- ☐ Policy reviewed at planned intervals or when significant changes occur

5.3 Organizational Roles, Responsibilities and Authorities

- ☐ Roles and responsibilities for information security are defined and assigned
- ☐ ISMS owner / Information Security Manager role defined
- ☐ Responsibilities documented (e.g., RACI matrix or job descriptions)
- ☐ Reporting lines for information security incidents are established

Clause 6 – Planning

6.1.2 Information Security Risk Assessment

- ☐ Risk assessment methodology defined and documented
- ☐ Risk acceptance criteria established
- ☐ Information assets identified and documented (Asset Inventory)
- ☐ Threats and vulnerabilities identified for each asset
- ☐ Risk likelihood and impact assessed
- ☐ Risk owners assigned for each identified risk
- ☐ Risk assessment performed at planned intervals or when major changes occur
- ☐ Risk assessment results documented

6.1.3 Information Security Risk Treatment

- ☐ Risk treatment options evaluated (accept, avoid, transfer, mitigate)
- ☐ Controls selected from Annex A (or justified if not applicable)
- ☐ Statement of Applicability (SoA) produced and maintained
- ☐ Risk treatment plan documented and approved by risk owners
- ☐ Residual risk accepted by risk owners

6.2 Information Security Objectives

- ☐ Information security objectives established at relevant functions and levels
- ☐ Objectives are measurable where practicable
- ☐ Plan documented for how objectives will be achieved

Clause 7 – Support

7.2 Competence

- ☐ Competence requirements for information security roles defined
- ☐ Training needs assessed and training provided or planned
- ☐ Evidence of competence retained (training records, certifications)

7.3 Awareness

- ☐ All personnel are aware of the Information Security Policy
- ☐ Employees understand their contribution to ISMS effectiveness
- ☐ Regular security awareness training conducted (at least annually)
- ☐ Phishing simulations or security tests performed

7.5 Documented Information

- ☐ Documents required by ISO 27001 are created and controlled
- ☐ Version control applied to ISMS documents
- ☐ Documents accessible to those who need them
- ☐ Retention and disposal rules defined for records

Clause 8 – Operation

- ☐ Processes needed to meet ISMS requirements are planned, implemented, and controlled
- ☐ Controls over externally provided processes, products, or services defined
- ☐ Risk assessments performed at planned intervals and triggered by significant changes
- ☐ Risk treatment plan implemented and evidence retained

Clause 9 – Performance Evaluation

9.1 Monitoring, Measurement, Analysis and Evaluation

- ☐ What needs to be monitored and measured defined
- ☐ Frequency of monitoring defined and performed
- ☐ Security metrics and KPIs tracked (patch rate, incident count, training completion)

9.2 Internal Audit

- ☐ Internal audit programme established with defined criteria, scope, and frequency
- ☐ Internal audits conducted at planned intervals (at least annually)
- ☐ Audit results reported to relevant management and records retained
- ☐ Corrective actions taken for audit findings

9.3 Management Review

- ☐ Management reviews ISMS at planned intervals (at least annually)
- ☐ Review outputs include decisions on improvement and resource needs
- ☐ Management review results documented and retained

Clause 10 – Improvement

- ☐ Opportunities for continual improvement identified and acted upon
- ☐ Process to handle nonconformities defined
- ☐ Root cause analysis performed for nonconformities
- ☐ Corrective actions implemented and their effectiveness reviewed
- ☐ Corrective action records retained

Annex A – Information Security Controls (ISO 27001:2022)

ISO 27001:2022 Annex A contains 93 controls organized into 4 themes. Complete the Status and Notes columns as part of your Statement of Applicability (SoA).

Theme 1: Organizational Controls (A.5) — 37 Controls

#	Control ID	Control Name	Status	Notes
1	**A.5.1**	Policies for information security	☐	
2	**A.5.2**	Information security roles and responsibilities	☐	
3	**A.5.3**	Segregation of duties	☐	
4	**A.5.4**	Management responsibilities	☐	
5	**A.5.5**	Contact with authorities	☐	
6	**A.5.6**	Contact with special interest groups	☐	
7	**A.5.7**	Threat intelligence	☐	
8	**A.5.8**	Information security in project management	☐	
9	**A.5.9**	Inventory of information and other associated assets	☐	
10	**A.5.10**	Acceptable use of information and other associated assets	☐	
11	**A.5.11**	Return of assets	☐	
12	**A.5.12**	Classification of information	☐	
13	**A.5.13**	Labelling of information	☐	
14	**A.5.14**	Information transfer	☐	
15	**A.5.15**	Access control	☐	
16	**A.5.16**	Identity management	☐	
17	**A.5.17**	Authentication information	☐	
18	**A.5.18**	Access rights	☐	
19	**A.5.19**	Information security in supplier relationships	☐	
20	**A.5.20**	Addressing information security within supplier agreements	☐	
21	**A.5.21**	Managing information security in the ICT supply chain	☐	
22	**A.5.22**	Monitoring, review and change management of supplier services	☐	
23	**A.5.23**	Information security for use of cloud services	☐	
24	**A.5.24**	Information security incident management planning and preparation	☐	
25	**A.5.25**	Assessment and decision on information security events	☐	

#	Control ID	Control Name	Status	Notes
26	**A.5.26**	Response to information security incidents	☐	
27	**A.5.27**	Learning from information security incidents	☐	
28	**A.5.28**	Collection of evidence	☐	
29	**A.5.29**	Information security during disruption	☐	
30	**A.5.30**	ICT readiness for business continuity	☐	
31	**A.5.31**	Legal, statutory, regulatory and contractual requirements	☐	
32	**A.5.32**	Intellectual property rights	☐	
33	**A.5.33**	Protection of records	☐	
34	**A.5.34**	Privacy and protection of PII	☐	
35	**A.5.35**	Independent review of information security	☐	
36	**A.5.36**	Compliance with policies, rules and standards	☐	
37	**A.5.37**	Documented operating procedures	☐	

Theme 2: People Controls (A.6) — 8 Controls

#	Control ID	Control Name	Status	Notes
1	**A.6.1**	Screening	☐	
2	**A.6.2**	Terms and conditions of employment	☐	
3	**A.6.3**	Information security awareness, education and training	☐	
4	**A.6.4**	Disciplinary process	☐	
5	**A.6.5**	Responsibilities after termination or change of employment	☐	
6	**A.6.6**	Confidentiality or non-disclosure agreements	☐	
7	**A.6.7**	Remote working	☐	
8	**A.6.8**	Information security event reporting	☐	

Theme 3: Physical Controls (A.7) — 14 Controls

#	Control ID	Control Name	Status	Notes
1	**A.7.1**	Physical security perimeters	☐	
2	**A.7.2**	Physical entry	☐	
3	**A.7.3**	Securing offices, rooms and facilities	☐	
4	**A.7.4**	Physical security monitoring	☐	
5	**A.7.5**	Protecting against physical and environmental threats	☐	

#	Control ID	Control Name	Status	Notes
6	**A.7.6**	Working in secure areas	☐	
7	**A.7.7**	Clear desk and clear screen	☐	
8	**A.7.8**	Equipment siting and protection	☐	
9	**A.7.9**	Security of assets off-premises	☐	
10	**A.7.10**	Storage media	☐	
11	**A.7.11**	Supporting utilities	☐	
12	**A.7.12**	Cabling security	☐	
13	**A.7.13**	Equipment maintenance	☐	
14	**A.7.14**	Secure disposal or re-use of equipment	☐	

Theme 4: Technological Controls (A.8) — 34 Controls

#	Control ID	Control Name	Status	Notes
1	**A.8.1**	User endpoint devices	☐	
2	**A.8.2**	Privileged access rights	☐	
3	**A.8.3**	Information access restriction	☐	
4	**A.8.4**	Access to source code	☐	
5	**A.8.5**	Secure authentication	☐	
6	**A.8.6**	Capacity management	☐	
7	**A.8.7**	Protection against malware	☐	
8	**A.8.8**	Management of technical vulnerabilities	☐	
9	**A.8.9**	Configuration management	☐	
10	**A.8.10**	Information deletion	☐	
11	**A.8.11**	Data masking	☐	
12	**A.8.12**	Data leakage prevention	☐	
13	**A.8.13**	Information backup	☐	
14	**A.8.14**	Redundancy of information processing facilities	☐	
15	**A.8.15**	Logging	☐	
16	**A.8.16**	Monitoring activities	☐	
17	**A.8.17**	Clock synchronisation	☐	
18	**A.8.18**	Use of privileged utility programs	☐	
19	**A.8.19**	Installation of software on operational systems	☐	
20	**A.8.20**	Networks security	☐	
21	**A.8.21**	Security of network services	☐	

#	Control ID	Control Name	Status	Notes
22	**A.8.22**	Segregation of networks	☐	
23	**A.8.23**	Web filtering	☐	
24	**A.8.24**	Use of cryptography	☐	
25	**A.8.25**	Secure development life cycle	☐	
26	**A.8.26**	Application security requirements	☐	
27	**A.8.27**	Secure system architecture and engineering principles	☐	
28	**A.8.28**	Secure coding	☐	
29	**A.8.29**	Security testing in development and acceptance	☐	
30	**A.8.30**	Outsourced development	☐	
31	**A.8.31**	Separation of development, test and production environments	☐	
32	**A.8.32**	Change management	☐	
33	**A.8.33**	Test information	☐	
34	**A.8.34**	Protection of information systems during audit testing	☐	

Startup & SME Quick-Start Priority List

If you are just getting started, focus on these high-impact, lower-effort controls first:

Control	Description	Priority	Status
A.5.1	Write and publish an Information Security Policy	**CRITICAL**	☐
A.5.9	Build an Asset Inventory	**CRITICAL**	☐
A.5.15/16	Implement Access Control and Identity Management	**CRITICAL**	☐
A.5.17	Password policy + Multi-Factor Authentication everywhere	**CRITICAL**	☐
A.6.3	Security awareness training for all staff	**CRITICAL**	☐
A.8.5	Enforce secure authentication (MFA, SSO)	**CRITICAL**	☐
A.8.7	Endpoint protection (antivirus/EDR on all devices)	**CRITICAL**	☐
A.8.13	Automated, tested backups	**CRITICAL**	☐
A.5.12	Classify your data (Public, Internal, Confidential, Restricted)	**HIGH**	☐
A.5.19/20	Review supplier security (especially SaaS vendors)	**HIGH**	☐
A.5.23	Cloud service security (review AWS/Azure/GCP settings)	**HIGH**	☐
A.5.24	Create an Incident Response Plan	**HIGH**	☐
A.6.1	Background screening for new hires with sensitive data access	**HIGH**	☐
A.6.6	NDAs for employees and contractors	**HIGH**	☐
A.8.8	Patch management process (keep systems updated)	**HIGH**	☐
A.8.15	Enable logging on critical systems	**HIGH**	☐

Recommended Document Set

Document	Description	Priority
Information Security Policy	Top-level commitment from leadership	**CRITICAL**
ISMS Scope	What is covered by your ISMS	**CRITICAL**
Asset Inventory	All information assets and owners	**CRITICAL**
Risk Assessment & Treatment	Risks identified, rated, and treated	**CRITICAL**
Statement of Applicability (SoA)	Which Annex A controls apply and why	**CRITICAL**
Acceptable Use Policy	Rules for using company systems	**HIGH**
Access Control Policy	Who can access what and how	**HIGH**
Incident Response Plan	How to respond to security incidents	**HIGH**
Business Continuity Plan	How to keep running during disruption	**HIGH**
Supplier Security Policy	Security requirements for third parties	**MEDIUM**
Data Classification Policy	How to label and handle data	**MEDIUM**
Secure Development Policy	Security in the SDLC	**MEDIUM**
Internal Audit Records	Evidence of audits performed	**MEDIUM**
Management Review Minutes	Evidence of leadership oversight	**MEDIUM**

Disclaimer: This checklist is for informational and educational purposes only and does not constitute legal or professional advice, nor does it guarantee ISO 27001 certification. Consult a qualified ISO 27001 consultant or certification body for formal assessments.